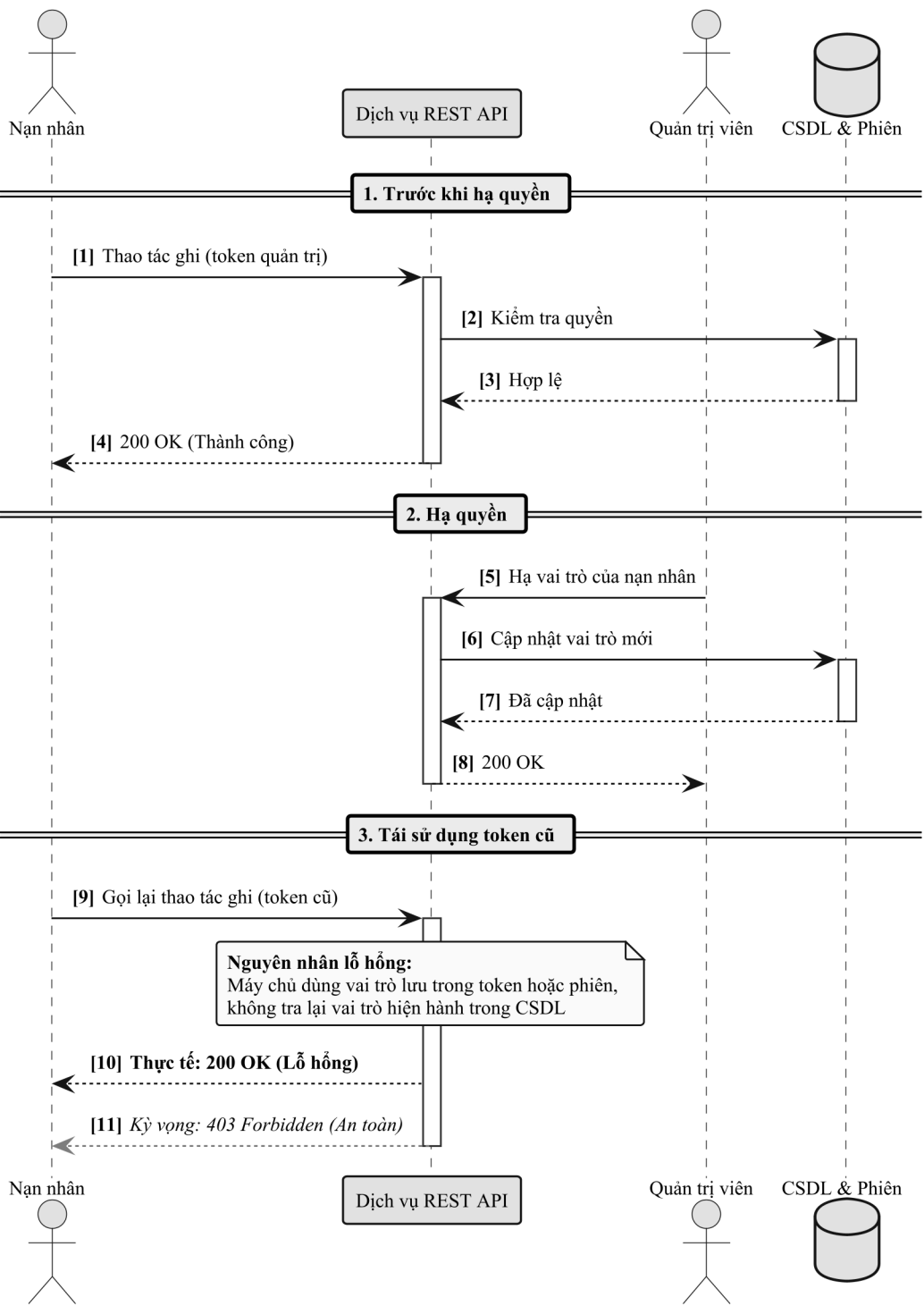

Nạn nhân
Dịch vụ REST API
Quản trị viên
CSDL & Phiên
1. Trước khi hạ quyền
[1] Thao tác ghi (token quản trị)
[2] Kiểm tra quyền
[3] Hợp lệ
[4] 200 OK (Thành công)
2. Hạ quyền
[5] Hạ vai trò của nạn nhân
[6] Cập nhật vai trò mới
[7] Đã cập nhật
[8] 200 OK
3. Tái sử dụng token cũ
[9] Gọi lại thao tác ghi (token cũ)
Nguyên nhân lỗ hổng:
Máy chủ dùng vai trò lưu trong token hoặc phiên, không tra lại vai trò hiện hành trong CSDL
[10] Thực tế: 200 OK (Lỗ hổng)
[11] Kỳ vọng: 403 Forbidden (An toàn)
Nạn nhân
Dịch vụ REST API
Quản trị viên
CSDL & Phiên